ZAP by Checkmarx Scanning Report

Generated with ZAP on Tue 5 May 2026, at 16:24:51

ZAP Version: 2.17.0

ZAP by Checkmarx

Contents

- About This Report
  - Report Parameters
- Summaries
  - Alert Counts by Risk and Confidence
  - Alert Counts by Site and Risk
  - Alert Counts by Alert Type
  - Insights
- Alerts
  - Risk=High, Confidence=Low (1)
  - Risk=Medium, Confidence=High (2)
  - Risk=Medium, Confidence=Medium (3)

- Risk=Low, Confidence=Medium (3)
- Risk=Low, Confidence=Low (1)
- Risk=Informational, Confidence=Medium (2)

- Appendix
  - Alert Types

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- http://localhost:3000

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: High, Medium, Low, Informational

Excluded: None

Confidence levels

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
		User Confirmed	**High**	**Medium**	**Low**	**Total**
Risk	**High**	0 (0.0%)	0 (0.0%)	0 (0.0%)	1 (8.3%)	1 (8.3%)
	Medium	0 (0.0%)	2 (16.7%)	3 (25.0%)	0 (0.0%)	5 (41.7%)
	Low	0 (0.0%)	0 (0.0%)	3 (25.0%)	1 (8.3%)	4 (33.3%)
	Informational	0 (0.0%)	0 (0.0%)	2 (16.7%)	0 (0.0%)	2 (16.7%)
	Total	0 (0.0%)	2 (16.7%)	8 (66.7%)	2 (16.7%)	12 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		Risk			
		High (= High)	Medium (>= Medium)	Low (>= Low)	Informational (>= Informational)
Site	http://localhost:3000	1 (1)	5 (6)	4 (10)	2 (12)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
SQL Injection	High	1 (8.3%)
Application Error Disclosure	Medium	1 (8.3%)
Content Security Policy (CSP) Header Not Set	Medium	2 (16.7%)
Total		12

Alert type	Risk	Count
Cross-Domain Misconfiguration	Medium	5 (41.7%)
Missing Anti-clickjacking Header	Medium	1 (8.3%)
Session ID in URL Rewrite	Medium	5 (41.7%)
Information Disclosure - Debug Error Messages	Low	1 (8.3%)
Private IP Disclosure	Low	1 (8.3%)
Timestamp Disclosure - Unix	Low	5 (41.7%)
X-Content-Type-Options Header Missing	Low	3 (25.0%)
Modern Web Application	Informational	1 (8.3%)
User Agent Fuzzer	Informational	3 (25.0%)
Total		12

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP warnings logged - see the zap.log file for details	2
Low	Exceeded High	http://localhost:3000	Percentage of responses with status code 4xx	52 %
Info	Informational		Percentage of network failures	1 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 1xx	3 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 2xx	39 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 3xx	5 %
Info	Exceeded Low	http://localhost:3000	Percentage of responses with status code 5xx	7 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/javascript	19 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/json	23 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type font/woff	2 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type font/woff2	2 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type image/jpeg	32 %

Level	Reason	Site	Description	Statistic
Info	Informational	http://localhost:3000	Percentage of endpoints with content type image/png	4 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type image/x-icon	2 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/css	2 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/html	4 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/plain	4 %
Info	Informational	http://localhost:3000	Percentage of endpoints with method GET	97 %
Info	Informational	http://localhost:3000	Percentage of endpoints with method POST	2 %
Info	Informational	http://localhost:3000	Count of total endpoints	46
Info	Exceeded Low	http://localhost:3000	Percentage of slow responses	11 %
Info	Informational	https://archive.mozilla.org	Percentage of responses with status code 2xx	100 %
Info	Informational	https://archive.mozilla.org	Percentage of endpoints with content type application/x-xpinstall	100 %
Info	Informational	https://archive.mozilla.org	Percentage of endpoints with method GET	100 %

Level	Reason	Site	Description	Statistic
Info	Informational	https://archive.mozilla.org	Count of total endpoints	1
Info	Informational	https://archive.mozilla.org	Percentage of slow responses	8 %

Alerts

Risk=High, Confidence=Low (1)

http://localhost:3000 (1)

SQL Injection (1)

▼ GET http://localhost:3000/rest/products/search?q=%27%28

Alert tags

- POLICY_SEQUENCE =
- OWASP_2021_A03
- PCI_DSS
- CWE-89
- POLICY_QA_CICD =
- POLICY_DEV_CICD =
- OWASP_2025_A05
- WSTG-v42-INPV-05
- POLICY_API =
- POLICY_DEV_FULL =
- POLICY_QA_STD =
- POLICY_QA_FULL =
- POLICY_PENTEST =
- HIPAA
- OWASP_2017_A01

	▪ API_2023_API10 ▪ POLICY_DEV_STD =
Alert description	SQL injection may be possible.
Request	▼ Request line and header section (457 bytes) GET http://localhost:3000/rest/products/search?q=%27%28 HTTP/1.1 host: localhost:3000 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0) Gecko/20100101 Firefox/150.0 Accept: application/json, text/plain, */* Accept-Language: en-US,en;q=0.9 Connection: keep-alive Referer: http://localhost:3000/ Cookie: language=en; welcomebanner_status=dismiss Sec-Fetch-Dest: empty Sec-Fetch-Mode: cors Sec-Fetch-Site: same-origin Priority: u=0 ▼ Request body (0 bytes)
Response	▼ Status line and header section (362 bytes) HTTP/1.1 500 Internal Server Error Access-Control-Allow-Origin: * X-Content-Type-Options: nosniff X-Frame-Options: SAMEORIGIN Feature-Policy: payment 'self' X-Recruiting: /#/jobs Content-Type: application/json;

```
charset=utf-8
Vary: Accept-Encoding
Date: Tue, 05 May 2026 14:37:00 GMT
Connection: keep-alive
Keep-Alive: timeout=5
content-length: 309
```

▼ Response body (309 bytes)

```
{
  "error": {
    "message": "SQLITE_ERROR: near \"
(\": syntax error",
    "stack": "Error: SQLITE_ERROR: near
\"(\": syntax error",
    "errno": 1,
    "code": "SQLITE_ERROR",
    "sql": "SELECT * FROM Products
WHERE ((name LIKE '%'(%' OR description
LIKE '%'(%') AND deletedAt IS NULL)
ORDER BY name"
  }
}
```

Parameter

q

Attack

'(

Evidence

HTTP/1.1 500 Internal Server Error

Solution

Do not trust client side input, even if there is client side validation in place.

In general, type check all data on the server side.

If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?'

If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries.

If database Stored Procedures can be used, use them.

Do *not* concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality!

Do not create dynamic SQL queries using simple string concatenation.

Escape all data received from the client.

Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input.

Apply the principle of least privilege by using the least privileged database user possible.

In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact.

Grant the minimum database access that is necessary for the application.

Risk=Medium, Confidence=High (2)

http://localhost:3000 (2)

Content Security Policy (CSP) Header Not Set (1)

▼ POST http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PtuZ9p8&sid=zNEKjEJUKc-Bp4mDAABY

Alert tags

- OWASP_2021_A05
- POLICY_QA_STD =
- POLICY_PENTEST =
- SYSTEMIC
- CWE-693
- OWASP_2017_A06
- OWASP_2025_A02

Alert description

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

Request

▼ Request line and header section (543 bytes)

```
POST http://localhost:3000/socket.io/?
EIO=4&transport=polling&t=PtuZ9p8&sid=zNE
KjEJUKc-Bp4mDAABY HTTP/1.1
host: localhost:3000
User-Agent: Mozilla/5.0 (Windows NT
10.0; Win64; x64; rv:150.0)
Gecko/20100101 Firefox/150.0
Accept: */*
Accept-Language: en-US,en;q=0.9
Content-type: text/plain;charset=UTF-8
Content-Length: 2
Origin: http://localhost:3000
Connection: keep-alive
Referer: http://localhost:3000/
Cookie: language=en;
welcomebanner_status=dismiss
Sec-Fetch-Dest: empty
```

	Sec-Fetch-Mode: cors Sec-Fetch-Site: same-origin ▼ Request body (2 bytes) 40
Response	▼ Status line and header section (213 bytes) HTTP/1.1 200 OK Access-Control-Allow-Origin: http://localhost:4200 Vary: Origin Content-Type: text/html Content-Length: 2 Date: Tue, 05 May 2026 14:30:57 GMT Connection: keep-alive Keep-Alive: timeout=5 ▼ Response body (2 bytes) ok
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Session ID in URL Rewrite (1)

▼ GET http://localhost:3000/socket.io/?EIO=4&transport=websocket&sid=zNEKjEJUKc-Bp4mDAABY

Alert tags	▪ CWE-598 ▪ OWASP_2021_A01 ▪ POLICY_QA_STD = ▪ POLICY_PENTEST = ▪ SYSTEMIC

	▪ WSTG-v42-SESS-04 ▪ OWASP_2017_A03 ▪ OWASP_2025_A01 ▪ POLICY_DEV_STD =
Alert description	URL rewrite is used to track user session ID. The session ID may be disclosed via cross-site referer header. In addition, the session ID might be stored in browser history or server logs.

Request	▼ Request line and header section (579 bytes)
	
	`GET http://localhost:3000/socket.io/?EIO=4&transport=websocket&sid=zNEKjEJUKc-Bp4mDAABY HTTP/1.1`
	`host: localhost:3000`
	`User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0) Gecko/20100101 Firefox/150.0`
	`Accept: */*`
	`Accept-Language: en-US,en;q=0.9`
	`Sec-WebSocket-Version: 13`
	`Origin: http://localhost:3000`
	`Sec-WebSocket-Key: JmZy40xk1hNuocotgCQUqw==`
	`Connection: Upgrade`
	`Cookie: language=en; welcomebanner_status=dismiss`
	`Sec-Fetch-Dest: empty`
	`Sec-Fetch-Mode: websocket`
	`Sec-Fetch-Site: same-origin`
	`Pragma: no-cache`
	`Cache-Control: no-cache`
	`Upgrade: websocket`
	
	▼ Request body (0 bytes)

Response	▼ Status line and header section (129 bytes)

	HTTP/1.1 101 Switching Protocols Upgrade: websocket Connection: Upgrade Sec-WebSocket-Accept: 4nCVsCgnsywiRbaEbakAKN47a44= ▼ Response body (0 bytes)
Parameter	sid
Evidence	zNEKjEJUKc-Bp4mDAABY
Solution	For secure content, put session ID in a cookie. To be even more secure consider using a combination of cookie and URL rewrite.

Risk=Medium, Confidence=Medium (3)

http://localhost:3000 (3)

Application Error Disclosure (1)

▼ GET http://localhost:3000/api/Hints/

Alert tags	▪ WSTG-v42-ERRH-02 ▪ WSTG-v42-ERRH-01 ▪ OWASP_2021_A05 ▪ POLICY_QA_STD = ▪ POLICY_PENTEST = ▪ CWE-550 ▪ OWASP_2017_A06 ▪ OWASP_2025_A02
Alert description	This page contains an error/warning message that may disclose sensitive information like the location of the file

	that produced the unhandled exception. This information can be used to launch further attacks against the web application. The alert could be a false positive if the error message is found inside a documentation page.

Request	▼ Request line and header section (438 bytes)
	
	`GET http://localhost:3000/api/Hints/ HTTP/1.1`
	`host: localhost:3000`
	`User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0) Gecko/20100101 Firefox/150.0`
	`Accept: application/json, text/plain, */*`
	`Accept-Language: en-US,en;q=0.9`
	`Connection: keep-alive`
	`Referer: http://localhost:3000/`
	`Cookie: language=en; welcomebanner_status=dismiss`
	`Sec-Fetch-Dest: empty`
	`Sec-Fetch-Mode: cors`
	`Sec-Fetch-Site: same-origin`
	`Priority: u=0`
	
	▼ Request body (0 bytes)

Response	▼ Status line and header section (390 bytes)
	
	`HTTP/1.1 200 OK`
	`Access-Control-Allow-Origin: *`
	`X-Content-Type-Options: nosniff`
	`X-Frame-Options: SAMEORIGIN`
	`Feature-Policy: payment 'self'`
	`X-Recruiting: /#/jobs`
	`Content-Type: application/json; charset=utf-8`
	`Content-Length: 93324`
	`ETag: W/"16c8c-`

	756YRwsq4+TZZv2gnT4FPbiU6q8" Vary: Accept-Encoding Date: Tue, 05 May 2026 14:32:02 GMT Connection: keep-alive Keep-Alive: timeout=5 ▶ Response body (93324 bytes)
Evidence	Internal Server Error
Solution	Review the source code of this page. Implement custom error pages. Consider implementing a mechanism to provide a unique error reference/identifier to the client (browser) while logging the details on the server side and not exposing them to the user.

Cross-Domain Misconfiguration (1)

▼ GET http://localhost:3000/chunk-24EZLZ4I.js

Alert tags	▪ OWASP_2021_A01 ▪ POLICY_QA_STD = ▪ POLICY_PENTEST = ▪ SYSTEMIC ▪ OWASP_2025_A01 ▪ OWASP_2017_A05 ▪ CWE-264
Alert description	Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.
Other info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated

APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.

Request

▼ Request line and header section (365 bytes)

```
GET http://localhost:3000/chunk-
24EZLZ4I.js HTTP/1.1
host: localhost:3000
User-Agent: Mozilla/5.0 (Windows NT 10.0;
Win64; x64; rv:150.0) Gecko/20100101
Firefox/150.0
Accept: */*
Accept-Language: en-US,en;q=0.9
Connection: keep-alive
Referer: http://localhost:3000/
Sec-Fetch-Dest: script
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=1
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (479 bytes)

```
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Tue, 14 Apr 2026 06:50:11
GMT
ETag: W/"55f-19d8ac134b8"
```

▼ Response body (1375 bytes)

import{f as i}from"./chunk-TWZW5B45.js";var p=i((k,l)=>{var v="ABCDEFGHIJKLMNOPQRSTUVWXYZabcdefghijklmnopqrstuvwxyz0123456789+/=";function c(r){this.message=r}c.prototype=new Error;c.prototype.name="InvalidCharacterError";function f(r){var e=String(r).replace(/=+$/,"");if(e.length%4==1)throw new c("'atob' failed: The string to be decoded is not correctly encoded.");for(var o=0,t,n,u=0,s="";n=e.charAt(u++);~n&&(t=o%4?t*64+n:n,o++%4)?s+=String.fromCharCode(255&t>>(-2*o&6)):0)n=v.indexOf(n);return s}l.exports=typeof window<"u"&&window.atob&&window.atob.bind(window)||f});var g=i((C,w)=>{var h=p();function y(r){return decodeURIComponent(h(r).replace(/(.)/g,function(e,o){var t=o.charCodeAt(0).toString(16).toUpperCase();return t.length<2&&(t="0"+t),"%"+t}))}w.exports=function(r){var e=r.replace(/-/g,"+").replace(/_/g,"/");switch(e.length%4){case 0:break;case 2:e+="==";break;case 3:e+="=";break;default:throw"Illegal

	`base64url string!"}try{return y(e)}catch{return h(e)}}});var m=i((E,d)=> {"use strict";var I=g();function a(r) {this.message=r}a.prototype=new Error;a.prototype.name="InvalidTokenError" ;d.exports=function(r,e){if(typeof r!="string")throw new a("Invalid token specified");e=e||{};var o=e.header===!0? 0:1;try{return JSON.parse(I(r.split(".") [o]))}catch(t){throw new a("Invalid token specified: "+t.message)}};d.exports.InvalidTokenError =a});export{m as a};`
Evidence	`Access-Control-Allow-Origin: *`
Solution	Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.

Missing Anti-clickjacking Header (1)

▼ `POST http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PtuZ9p8&sid=zNEKjEJUKc-Bp4mDAABY`

Alert tags	▪ OWASP_2021_A05 ▪ POLICY_QA_STD = ▪ POLICY_PENTEST = ▪ CWE-1021 ▪ SYSTEMIC ▪ WSTG-v42-CLNT-09 ▪ OWASP_2017_A06 ▪ OWASP_2025_A02

Alert description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

Request	▼ Request line and header section (543 bytes)
	
	`POST http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PtuZ9p8&sid=zNEKjEJUKc-Bp4mDAABY HTTP/1.1`
	`host: localhost:3000`
	`User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0) Gecko/20100101 Firefox/150.0`
	`Accept: */*`
	`Accept-Language: en-US,en;q=0.9`
	`Content-type: text/plain;charset=UTF-8`
	`Content-Length: 2`
	`Origin: http://localhost:3000`
	`Connection: keep-alive`
	`Referer: http://localhost:3000/`
	`Cookie: language=en; welcomebanner_status=dismiss`
	`Sec-Fetch-Dest: empty`
	`Sec-Fetch-Mode: cors`
	`Sec-Fetch-Site: same-origin`
	
	▼ Request body (2 bytes)
	
	`40`

Response	▼ Status line and header section (213 bytes)
	
	`HTTP/1.1 200 OK`
	`Access-Control-Allow-Origin: http://localhost:4200`
	`Vary: Origin`
	`Content-Type: text/html`
	`Content-Length: 2`
	`Date: Tue, 05 May 2026 14:30:57 GMT`

	Connection: keep-alive Keep-Alive: timeout=5 ▼ Response body (2 bytes) ok
Parameter	x-frame-options
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

Risk=Low, Confidence=Medium (3)

http://localhost:3000 (3)

Information Disclosure - Debug Error Messages (1)

▼ GET http://localhost:3000/api/Hints/

Alert tags	▪ OWASP_2021_A01 ▪ WSTG-v42-ERRH-01 ▪ OWASP_2017_A03 ▪ OWASP_2025_A01 ▪ CWE-1295 ▪ POLICY_PENTEST =

Alert description	The response appeared to contain common error messages returned by platforms such as ASP.NET, and Web-servers such as IIS and Apache. You can configure the list of common debug messages.

Request	▼ Request line and header section (438 bytes)
	
	`GET http://localhost:3000/api/Hints/ HTTP/1.1`
	`host: localhost:3000`
	`User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0) Gecko/20100101 Firefox/150.0`
	`Accept: application/json, text/plain, */*`
	`Accept-Language: en-US,en;q=0.9`
	`Connection: keep-alive`
	`Referer: http://localhost:3000/`
	`Cookie: language=en; welcomebanner_status=dismiss`
	`Sec-Fetch-Dest: empty`
	`Sec-Fetch-Mode: cors`
	`Sec-Fetch-Site: same-origin`
	`Priority: u=0`
	
	▼ Request body (0 bytes)

Response	▼ Status line and header section (390 bytes)
	
	`HTTP/1.1 200 OK`
	`Access-Control-Allow-Origin: *`
	`X-Content-Type-Options: nosniff`
	`X-Frame-Options: SAMEORIGIN`
	`Feature-Policy: payment 'self'`
	`X-Recruiting: /#/jobs`
	`Content-Type: application/json; charset=utf-8`
	`Content-Length: 93324`
	`ETag: W/"16c8c-`

	756YRwsq4+TZZv2gnT4FPbiU6q8" Vary: Accept-Encoding Date: Tue, 05 May 2026 14:32:02 GMT Connection: keep-alive Keep-Alive: timeout=5 ▶ Response body (93324 bytes)
Evidence	Internal Server Error
Solution	Disable debugging messages before pushing to production.

Private IP Disclosure (1)

▼ GET http://localhost:3000/rest/admin/application-configuration

Alert tags	▪ OWASP_2021_A01 ▪ OWASP_2017_A03 ▪ OWASP_2025_A01 ▪ POLICY_QA_STD = ▪ POLICY_PENTEST = ▪ CWE-497
Alert description	A private IP (such as 10.x.x.x, 172.x.x.x, 192.168.x.x) or an Amazon EC2 private hostname (for example, ip-10-0-56-78) has been found in the HTTP response body. This information might be helpful for further attacks targeting internal systems.
Other info	192.168.99.100:3000 192.168.99.100:4200
Request	▼ Request line and header section (398 bytes)

```
GET
http://localhost:3000/rest/admin/applicat
ion-configuration HTTP/1.1
host: localhost:3000
User-Agent: Mozilla/5.0 (Windows NT
10.0; Win64; x64; rv:150.0)
Gecko/20100101 Firefox/150.0
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.9
Connection: keep-alive
Referer: http://localhost:3000/
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (389 bytes)

```
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Content-Type: application/json;
charset=utf-8
Content-Length: 21770
ETag: W/"550a-
OEo3agZPnY9Z7Todze3/X9Rt2J8"
Vary: Accept-Encoding
Date: Tue, 05 May 2026 14:31:05 GMT
Connection: keep-alive
Keep-Alive: timeout=5
```

▶ Response body (21770 bytes)

Evidence	`192.168.99.100:3000`
Solution	Remove the private IP address from the HTTP response body. For comments, use JSP/ASP/PHP comment instead of HTML/JavaScript comment which can be seen by client browsers.

X-Content-Type-Options Header Missing (1)

▼ `GET http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PtuZ9oo`

Alert tags	▪ OWASP_2021_A05 ▪ POLICY_QA_STD = ▪ POLICY_PENTEST = ▪ SYSTEMIC ▪ CWE-693 ▪ OWASP_2017_A06 ▪ OWASP_2025_A02
Alert description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
Other info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.

Request

▼ Request line and header section (427 bytes)

```
GET http://localhost:3000/socket.io/?
EIO=4&transport=polling&t=PtuZ9oo
HTTP/1.1
host: localhost:3000
User-Agent: Mozilla/5.0 (Windows NT
10.0; Win64; x64; rv:150.0)
Gecko/20100101 Firefox/150.0
Accept: */*
Accept-Language: en-US,en;q=0.9
Connection: keep-alive
Referer: http://localhost:3000/
Cookie: language=en;
welcomebanner_status=dismiss
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (230 bytes)

```
HTTP/1.1 200 OK
Access-Control-Allow-Origin:
http://localhost:4200
Vary: Origin
Content-Type: text/plain; charset=UTF-8
Content-Length: 96
Date: Tue, 05 May 2026 14:30:57 GMT
Connection: keep-alive
Keep-Alive: timeout=5
```

▼ Response body (96 bytes)

```
0{"sid":"zNEKjEJUKc-
Bp4mDAABY","upgrades":
```

	`["websocket"],"pingInterval":25000,"pingTimeout":5000}`
Parameter	`x-content-type-options`
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.

Risk=Low, Confidence=Low (1)

`http://localhost:3000` (1)

Timestamp Disclosure - Unix (1)

▼ `GET http://localhost:3000/`

Alert tags	▪ OWASP_2021_A01 ▪ OWASP_2017_A03 ▪ OWASP_2025_A01 ▪ POLICY_PENTEST = ▪ CWE-497 ▪ SYSTEMIC
Alert description	A timestamp was disclosed by the application/web server. - Unix
Other info	1650485437, which evaluates to: 2022-04-20 21:10:37.

Request

▼ Request line and header section (427 bytes)

```
GET http://localhost:3000/ HTTP/1.1
host: localhost:3000
User-Agent: Mozilla/5.0 (Windows NT
10.0; Win64; x64; rv:150.0)
Gecko/20100101 Firefox/150.0
Accept:
text/html,application/xhtml+xml,applicat
ion/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.9
Connection: keep-alive
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: none
Sec-Fetch-User: ?1
Priority: u=0, i
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (469 bytes)

```
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Sun, 03 May 2026
21:33:21 GMT
ETag: W/"124fa-19defc29a39"
Content-Type: text/html; charset=UTF-8
Content-Length: 75002
Vary: Accept-Encoding
Date: Tue, 05 May 2026 14:31:04 GMT
```

	Connection: keep-alive Keep-Alive: timeout=5 ▶ Response body (75002 bytes)
Evidence	1650485437
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.

Risk=Informational, Confidence=Medium (2)

http://localhost:3000 (2)

Modern Web Application (1)

▼ GET http://localhost:3000/

Alert tags	▪ OWASP_2021_A05 ▪ POLICY_QA_STD = ▪ POLICY_PENTEST = ▪ SYSTEMIC ▪ OWASP_2017_A06 ▪ OWASP_2025_A02 ▪ POLICY_DEV_STD =
Alert description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
Other info	No links have been found while there are scripts, which is an indication that this is a modern web application.

Request

▼ Request line and header section (427 bytes)

```
GET http://localhost:3000/ HTTP/1.1
host: localhost:3000
User-Agent: Mozilla/5.0 (Windows NT
10.0; Win64; x64; rv:150.0)
Gecko/20100101 Firefox/150.0
Accept:
text/html,application/xhtml+xml,applicati
on/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.9
Connection: keep-alive
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: none
Sec-Fetch-User: ?1
Priority: u=0, i
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (469 bytes)

```
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Sun, 03 May 2026 21:33:21
GMT
ETag: W/"124fa-19defc29a39"
Content-Type: text/html; charset=UTF-8
Content-Length: 75002
Vary: Accept-Encoding
Date: Tue, 05 May 2026 14:31:04 GMT
```

```
Connection: keep-alive
Keep-Alive: timeout=5
```

▶ Response body (75002 bytes)

Evidence

```
<script>
    window.addEventListener("load",
function(){
      window.cookieconsent.initialise({
        "palette": {
          "popup": { "background": "var(-
-theme-primary)", "text": "var(--theme-
text)" },
          "button": { "background":
"var(--theme-accent)", "text": "var(--
theme-text)" }
        },
        "theme": "classic",
        "position": "bottom-right",
        "content": { "message": "This
website uses fruit cookies to ensure you
get the juiciest tracking experience.",
"dismiss": "Me want it!", "link": "But
me wait!", "href":
"https://www.youtube.com/watch?
v=9PnbKL3wuH4" }
      })});
  </script>
```

Solution

This is an informational alert and so no changes are required.

User Agent Fuzzer (1)

▼ GET http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PtuZBbE

Alert tags	▪ CUSTOM_PAYLOADS = ▪ POLICY_PENTEST = ▪ SYSTEMIC
Alert description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.

Request	▼ Request line and header section (346 bytes)
	
	`GET http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PtuZBbE HTTP/1.1`
	`host: localhost:3000`
	`user-agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)`
	`Accept: */*`
	`Accept-Language: en-US,en;q=0.9`
	`Connection: keep-alive`
	`Referer: http://localhost:3000/`
	`Sec-Fetch-Dest: empty`
	`Sec-Fetch-Mode: cors`
	`Sec-Fetch-Site: same-origin`
	
	▼ Request body (0 bytes)

Response	▼ Status line and header section (230 bytes)
	
	`HTTP/1.1 200 OK`
	`Access-Control-Allow-Origin: http://localhost:4200`
	`Vary: Origin`
	`Content-Type: text/plain; charset=UTF-8`
	`Content-Length: 96`
	`Date: Tue, 05 May 2026 14:38:23 GMT`

	Connection: keep-alive Keep-Alive: timeout=5 ▼ Response body (96 bytes) 0{"sid":"O384n2OpWA_Rv8nsAAH4","upgrades" : ["websocket"],"pingInterval":25000,"pingT imeout":5000}
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

SQL Injection

Source	raised by an active scanner (SQL Injection)
CWE ID	89
WASC ID	19
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

Application Error Disclosure

Source	raised by a passive scanner (Application Error Disclosure)
CWE ID	550
WASC ID	13

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP ▪ https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html ▪ https://www.w3.org/TR/CSP/ ▪ https://w3c.github.io/webappsec-csp/ ▪ https://web.dev/articles/csp ▪ https://caniuse.com/#feat=contentsecuritypolicy ▪ https://content-security-policy.com/

Cross-Domain Misconfiguration

Source	raised by a passive scanner (Cross-Domain Misconfiguration)

CWE ID	264
WASC ID	14
Reference	▪ https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy

Missing Anti-clickjacking Header

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Session ID in URL Rewrite

Source	raised by a passive scanner (Session ID in URL Rewrite)
CWE ID	598
WASC ID	13
Reference	▪ https://seclists.org/webappsec/2002/q4/111

Information Disclosure - Debug Error Messages

Source	raised by a passive scanner (Information Disclosure - Debug Error Messages)
CWE ID	1295
WASC ID	13

Private IP Disclosure

Source	raised by a passive scanner (Private IP Disclosure)
CWE ID	497
WASC ID	13
Reference	▪ https://datatracker.ietf.org/doc/html/rfc1918

Timestamp Disclosure - Unix

Source	raised by a passive scanner (Timestamp Disclosure)
CWE ID	497
WASC ID	13
Reference	▪ https://cwe.mitre.org/data/definitions/200.html

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
Reference	▪ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) ▪ https://owasp.org/www-community/Security_Headers

Modern Web Application

Source	raised by a passive scanner (Modern Web Application)

User Agent Fuzzer

Source	raised by an active scanner (User Agent Fuzzer)
Reference	▪ https://owasp.org/wstg

